

Федеральное государственное автономное образовательное учреждение
высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность
**Работа 4: Анализ уязвимостей веб-приложения с помощью
OWASP ZAP**

Выполнил:

Баянов Равиль Динарович

Группа:

P3434

г. Санкт-Петербург

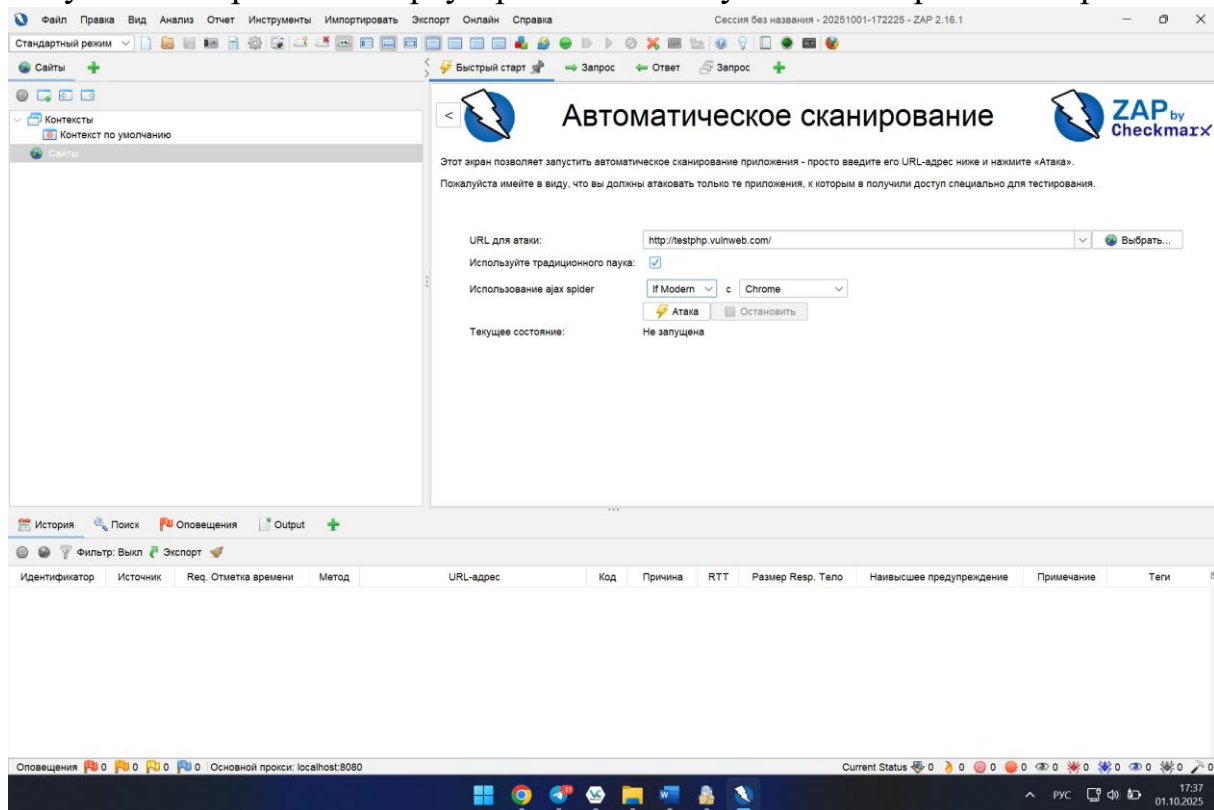
2025

Содержание

СКРИНШОТЫ С ОПИСАНИЕМ УЯЗВИМОСТЕЙ	3
Вывод	8

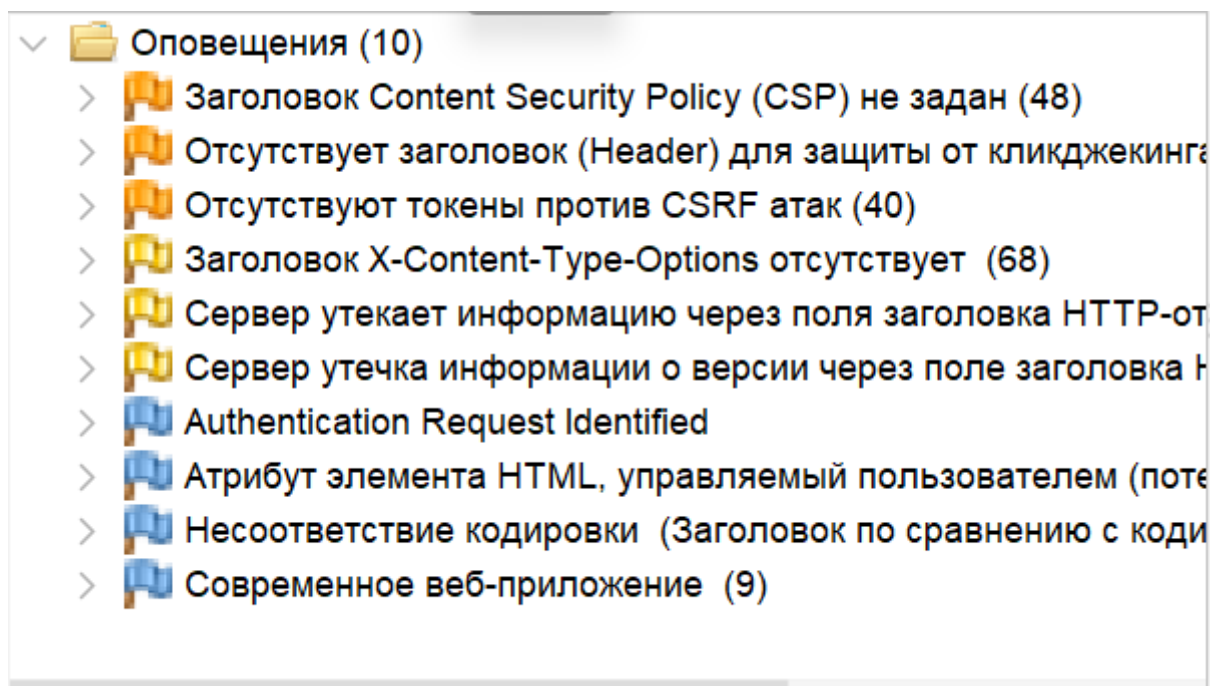
Скриншоты с описанием уязвимостей

Запустим встроенный браузер ZAP и запустим быстрое сканирование:



Был выбран URL для атаки: <http://testphp.vulnweb.com/>

Результаты сканирования:



Атрибут HTML, управляемый пользователем (потенциальный XSS)

Уязвимость DOM-based XSS – уязвимость, которая позволяет через поля ввода и другие различные способы пользователя внести любые данные. Данная уязвимость позволяет внести JavaScript код, который вставится в DOM сайта и выполнит всё что пожелаешь. Таким образом, можно воровать cookie, перенаправлять пользователей на другие сайты и изменять внешний вид сайта.

Атрибут элемента HTML, управляемый пользователем (потенциальный XSS)

URL-адрес: <http://testphp.vulnweb.com/search.php?test=query>

Риск: Informational

Достоверность: Low

Параметр: goButton

Атака:

Доказательства:

CWE ID: 20

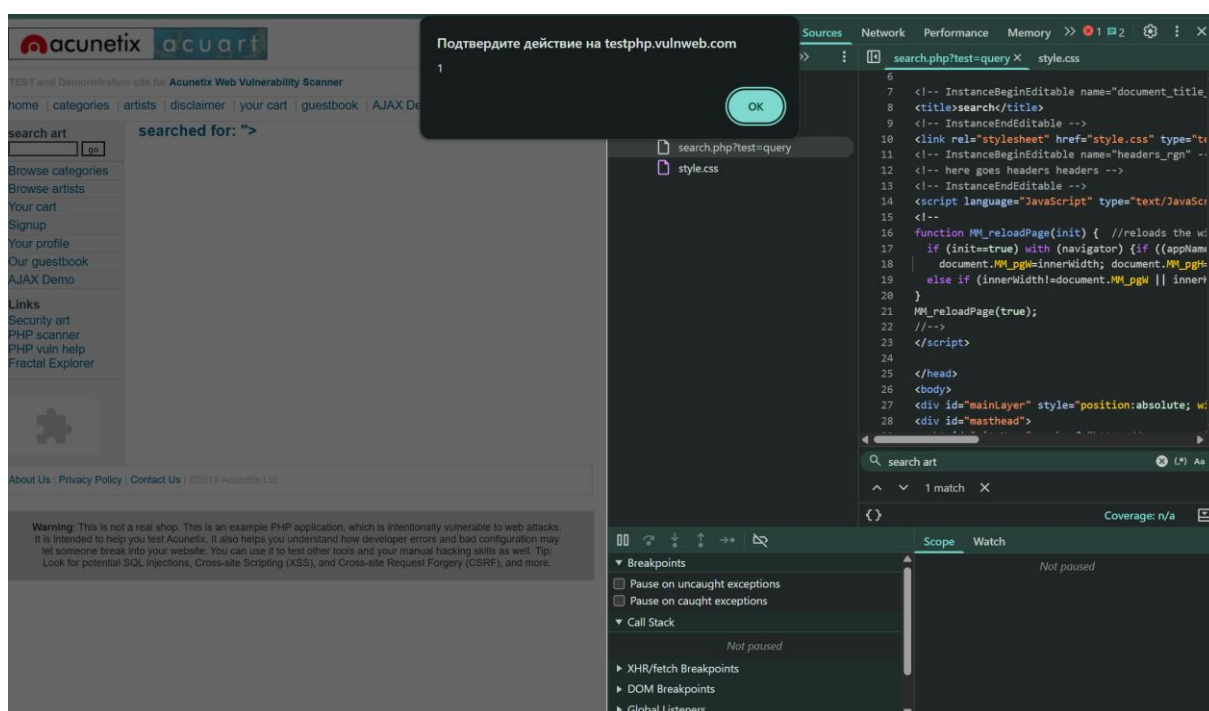
WASC ID: 20

Источник: Пассивный (10031 - Атрибут элемента HTML, управляемый пользователем (потенциальный XSS))

Input Vector:

Описание:

Эта проверка проверяет вводимые пользователем данные в параметрах строки запроса и данных POST, чтобы определить, где можно управлять определенными значениями атрибутов HTML. Это обеспечивает обнаружение горячих точек для XSS (межсайтового сценария), который потребует дальнейшего изучения аналитиком безопасности для



Таким вот способом можно вывести окно-alert через поля ввода.

Название: Reflected XSS

Категория: OWASP: A03:2021-Injection

Способ устранения: валидировать входные данные и не вставлять входные данные в DOM в HTML тег без использования отдельных JS методов для этого.

Отсутствуют токены против CSRF-атак

Данная уязвимость позволяет злоумышленнику через авторизованного пользователя выполнить нежелательное действие на другом сайте без ведома пользователя. Пользователь входит на свой сайт и авторизуется в нём, затем пользователь посещает вредоносный сайт, который благодаря сессионным кукам может получить доступ к сайту, на который пользователь недавно заходил.

Таким образом, можно изменить пароль на сайте, изменить настройки аккаунта, публиковать контент от имени пользователя и т. д.

Отсутствуют токены против CSRF атак
URL-адрес: <http://testphp.vulnweb.com/cart.php>
Риск:  Medium
Достоверность: Low
Параметр:
Атака:
Доказательства: <form action="search.php?test=query" method="post">
CWE ID: 352
WASC ID: 9
Источник: Пассивный (10202 - Отсутствуют токены против CSRF атак)
Input Vector:
Описание:
Токены для обезвреживания атак CSRF не были обнаружены в форме отправки на странице HTML.
Подделка межсайтового запроса - это атака, которая включает в себя принуждение жертвы к отправке HTTP-запроса в целевой пункт назначения без ее ведома или намерения, чтобы выполнить действие в качестве жертвы. Основная

Название: Отсутствуют анти-CSRF токены

Категория OWASP: A01:2021 – Broken Access Control

Способ устранения: Добавить CSRF токены, которые будут проверяться на совпадение с токеном, хранящимся в сессии пользователя.

Отсутствует заголовок (Header) для защиты от кликджекинга

Отсутствует заголовок (Header) для защиты от кликджекинга
URL-адрес: <http://testphp.vulnweb.com/artists.php>
Риск:  Medium
Достоверность: Medium
Параметр: x-frame-options
Атака:
Доказательства:
CWE ID: 1021
WASC ID: 15
Источник: Пассивный (10020 - Заголовок против кликджекинга)
Alert Reference: 10020-1
Input Vector:
Описание:
The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Данная уязвимость позволяет злоумышленнику накладывать фреймы вашего сайта на поверх своей вредоносной страницы. Это даёт возможность через нажатия пользователя сделать с его аккаунтом на сайте всё что угодно

Название: Отсутствует защита от clickjacking

Категория OWASP: A05:2021 - Security Misconfiguration

Способы устранения: Добавить заголовок X-Frame-Options, который запрещает отображать страницу во фрейме

Сервер утекает информацию через поля заголовка HTTP-ответа "X-Powered-By"

Сервер утекает информацию через поля заголовка HTTP-ответа "X-Powered-By"
URL-адрес: <http://testphp.vulnweb.com/userinfo.php>
Риск:  Low
Достоверность: Medium
Параметр:
Атака:
Доказательства: X-Powered-By: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1
CWE ID: 497
WASC ID: 13
Источник: Пассивный (10037 - Сервер утекает информацию через поля заголовка HTTP-ответа "X-Powered-By")
Input Vector:
Описание:
Веб-сервер / сервер приложений пропускает информацию через один или несколько заголовков HTTP-ответа «X-Powered-By». Доступ к такой информации может облегчить злоумышленникам идентификацию других фреймворков / компонентов.

Данная уязвимость позволяет злоумышленнику получить всю информацию о технологическом стеке приложения и впоследствии воспользоваться этим знанием.

Название: Раскрытие информации о технологическом стеке через служебные HTTP-заголовки

Категория OWASP: A05:2021 – Security Misconfiguration (Небезопасная конфигурация)

Способы устранения: Удаление информативных заголовков или настройка безопасной конфигурации сервера.

Заголовок Content Security Policy (CSP) не задан

Данная уязвимость упрощает использование XSS, так как заголовок CSP запрещает выполнение скриптов только с определенных источников.

Иначе злоумышленник может выполнить любой скрипт на вашем сайте и украсть данные.

Название: Отсутствует политика Content Security Policy (CSP)

Категория OWASP: A05:2021 – Security Misconfiguration

Способ устранения: Настроить минимальную конфигурацию CSP

Заголовок Content Security Policy (CSP) не задан

URL-адрес: <http://testphp.vulnweb.com/privacy.php>

Риск:  Medium

Достоверность: High

Параметр:

Атака:

Доказательства:

CWE ID: 693

WASC ID: 15

Источник: Пассивный (10038 - Заголовок Content Security Policy (CSP) не задан)

Alert Reference: 10038-1

Input Vector:

Описание:

Политика безопасности содержимого (CSP) — это дополнительный уровень безопасности, который помогает обнаруживать и смягчать определенные типы атак, включая межсайтовые сценарии (XSS) и атаки с внедрением данных. Эти атаки используются для всего: от кражи данных до порчи сайта или распространения вредоносных программ. CSP

Вывод

Выполнив данную лабораторную работу, я проанализировал сайт на наличие уязвимостей и потренировался в идентификации этих уязвимостей.